



Consultant Instructions Document: ISO 27001 Lead Implementer & Lead Auditor

General Objective: To provide comprehensive guidance, oversight, and training supervision for the qualification of the candidate to achieve both the **ISO 27001 Lead Implementer** and **ISO 27001 Lead Auditor** certifications, strictly adhering to the latest standard version (ISO/IEC 27001:2022).

1. General Principles & Core Guidelines

- **Methodological Separation:** The consultant must explain and establish the core methodologies separately. The approach for **building and operating a system (Implementation)** fundamentally differs from the approach for **verification and evaluation (Auditing)**. This aligns with the strict governance principle: *"The builder cannot audit their own work."*
- **Practical & Hands-on Approach:** Instruction must transcend theoretical definitions. The consultant should utilize real-world case studies, project documentation, and standard artifacts used in live deployment environments.
- **Focus on the 2022 Revision:** All training must center completely on the 2022 edition, highlighting critical changes from the 2013 version (such as the restructuring of the Annex A controls into 4 consolidated themes).

2. Consultant Responsibilities: ISO 27001 Lead Implementer Pathway

The consultant is directed to cover and qualify the candidate across the complete PDCA (Plan-Do-Check-Act) lifecycle:

- **Planning Phase (Plan):**
 - Guide the candidate on defining the Context of the Organization and establishing the precise ISMS Scope.
 - Demonstrate how to secure leadership commitment and draft an effective Information Security Policy.
 - Provide intensive training on **Risk Assessment and Risk Treatment methodologies**, aligned with ISO/IEC 27005 guidelines.
- **Implementation Phase (Do):**

- Master the drafting of the **Statement of Applicability (SoA)** and selecting relevant controls from Annex A.
- Formulate the Risk Treatment Plan (RTP) and deploy administrative, technical, physical, and organizational controls.
- Structure effective Information Security Awareness programs.
- **Evaluation & Improvement (Check & Act):**
 - Define key performance indicators (KPIs) to measure ISMS effectiveness.
 - Structure and conduct formal Management Reviews.

3. Consultant Responsibilities: ISO 27001 Lead Auditor Pathway

The consultant is directed to build and refine the candidate's auditing competencies based on the auditing guidelines of \$ISO 19011\$:

- **Audit Principles:** Establish the fundamentals of independence, integrity, professional care, and evidence-based auditing.
- **Managing an Audit Program:** Instruct on how to develop an Audit Plan, define audit objectives, and outline scopes for both internal and external audits.
- **Executing the Audit:**
 - Draft comprehensive Audit Checklists.
 - Master interviewing techniques, sampling, and collecting objective Audit Evidence.
 - Properly document and classify **Non-Conformities (NCs)** into Major and Minor findings.
- **Reporting & Follow-up:** Draft the final Audit Report and validate the effectiveness of proposed Corrective Actions.

4. Expected Deliverables from the Consultant

1. Provide Mock Exams & Question Banks: Exam Readiness.

Supply simulation exams matching official certification bodies (e.g., PECB) and conduct thorough review sessions to analyze incorrect answers.

2. Review & Analyze Practical Templates: Practical Application.

Provide and review live templates for key documentation, including the Risk Register, Statement of Applicability (SoA), Audit Plans, and Non-Conformity (NC) Reports.

3. Conduct Vetting & Oral Evaluation Sessions: Readiness Assessment.

Hold interactive Q&A sessions to test the candidate's ability to handle complex scenario-based questions and formal audit interviews.

 **Important Note for the Consultant:** Please place a heavy emphasis on "real-world" GRC scenarios where technical controls intersect with governance. The ultimate goal of this engagement is not merely passing the examinations, but ensuring the candidate is fully capable of leading end-to-end compliance and audit engagements with confidence.